

GRC102 – Information Security Governance

Information Security Governance in Action

Week 1 Practical Laboratory

Student Name: Faith Mathapelo Letsoara

Registration number: C11/26/CGRC/17582

Cohort /Batch: Cohort 11

Instructor Name: Phezulu Dhlodhlo and Ene Rita Otal

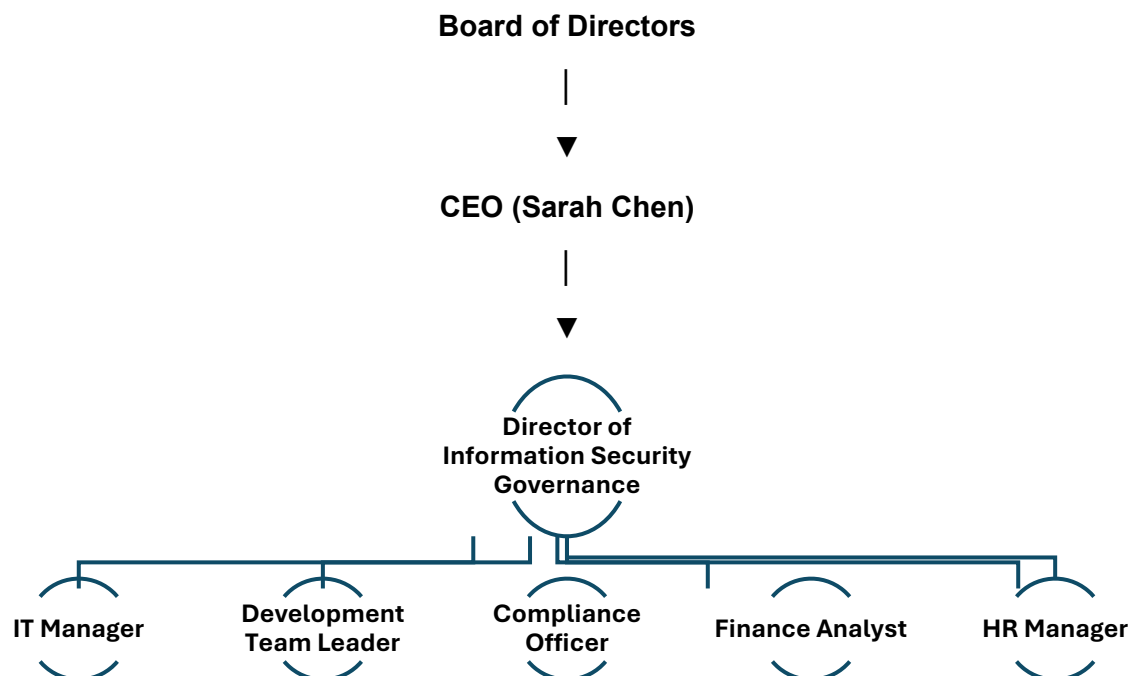
Date of Submission: 11/09/2026

Task 1: Governance Blueprint

1.1 Current-State Governance Gap Assessment

Weakness	Impact
No dedicated security governance function	Security activities are performed inconsistently across departments
Unclear accountability	Staff are unsure who owns security decisions
Lack of formal reporting structure	Board receives limited security visibility
Reactive risk management	Threats are addressed only after incidents occur
Inconsistent policies after acquisitions	Different teams follow different security practices
Weak cross-functional coordination	Security decisions conflict with business objectives

1.2 Proposed Governance Structure



Reporting Relationships

- Board provides oversight.
- CEO sponsors security governance.
- Director of Information Security Governance manages security strategy.
- IT, Development, Compliance, Finance and HR support governance activities.

1.3 RACI Matrix

Activity	Board	CEO	Security Director	IT Manager	Compliance Officer	HR
Security Policy Approval	A	C	R	I	C	I
Risk Assessment	I	A	R	C	C	I
Incident Response Planning	I	A	R	R	C	I
Security Awareness Training	I	A	C	I	C	R
Compliance Monitoring	I	C	R	I	A	I
Board Reporting	A	C	R	I	I	I

R = Responsible A = Accountable C = Consulted I = Informed

1.4 Governance Rationale

The proposed governance structure gives GlobalHealth Connect clear ownership and accountability for information security activities. By introducing a dedicated security governance function, employees understand who is responsible for security decisions and risk management. Regular reporting to executive management and the Board also improves transparency and ensures security remains a business priority.

In addition, the structure helps align security initiatives with the organisation's strategic goals, such as protecting patient data, maintaining regulatory compliance, and supporting business growth. Instead of treating security as only a technical issue, the proposed model encourages security to be considered in business decisions, helping GHC build customer trust and manage risks more effectively.

Task 2: Information Security Charter

GlobalHealth Connect Information Security Charter

Purpose

The Information Security Programme at GlobalHealth Connect is designed to protect the organisation's information assets, patient data, technology systems, and overall reputation. As a healthcare technology provider, GHC relies heavily on customer trust and the secure handling of sensitive information.

The programme also supports the organisation's broader business goals by enabling growth, encouraging innovation, ensuring compliance with regulatory requirements, and maintaining reliable business operations. By taking a proactive approach to information security, GHC can reduce risk, protect its stakeholders, and continue delivering secure and trusted services to its customers.

Scope

This charter applies to all employees, contractors, consultants, and third-party service providers who access or manage GHC information and systems. It covers all company-owned and cloud-based systems, applications, networks, devices, patient information, financial records, and other business-critical data.

The charter also applies to new business units, acquired organisations, and any external partners who process information on behalf of GHC.

The programme applies to:

- Employees
- Contractors
- Third-party vendors
- Information assets
- Applications
- Cloud services
- Infrastructure
- Business processes
- Patient and customer data

Authority

The Information Security Programme operates under the authority of the CEO and the Board of Directors. The Director of Information Security Governance is responsible for overseeing the programme and ensuring that security policies, standards, and procedures are implemented across the organisation. The Director has the authority to assess security risks, recommend appropriate controls, conduct governance reviews, and escalate significant risks or incidents to executive management when necessary.

Roles and Responsibilities

Board of Directors-The Board provides oversight of information security and ensures that security risks are managed appropriately within the organisation.

CEO-The CEO supports the Information Security Programme and ensures that security initiatives align with business objectives and strategic priorities.

Director of Information Security Governance-The Director leads the security governance programme, develops policies and standards, monitors risks, and reports security performance to executive management and the Board.

IT Manager-The IT Manager is responsible for implementing technical security controls and supporting secure day-to-day operations.

Compliance Officer-The Compliance Officer ensures that the organisation meets relevant healthcare, privacy, and regulatory requirements.

Department Managers-Department managers are responsible for ensuring that employees within their teams follow security policies, complete required training, and support security initiatives.

Employees-All employees share responsibility for protecting information assets and complying with security policies and procedures.

Key Principles

The Information Security Programme will be guided by the following principles:

- Security decisions should be based on risk and business needs.
- Security must support organisational goals rather than hinder them.
- The protection of patient information is a top priority.
- Compliance requirements must be continuously monitored and maintained.
- Security responsibilities should be clearly defined and understood.
- Continuous improvement should be encouraged to address emerging threats and changing business requirements.

Reporting Structure

- The Director of Information Security Governance will provide regular updates to executive management and the Security Steering Committee regarding security risks, compliance activities, incidents, and programme performance.
- A summary of security performance and major risks will be presented to the Board on a quarterly basis. Any significant security incident or high-risk issue will be escalated immediately to executive leadership.

Review and Approval

- This charter will be reviewed annually or whenever significant organisational, regulatory, or technological changes occur. Updates must be approved by the CEO and the Board of Directors before implementation.

Justification Memo to Marcus Thorne (CFO)

To: Marcus Thorne, Chief Financial Officer

From: Director of Information Security Governance

Subject: Information Security Charter Justification

The Information Security Charter provides GlobalHealth Connect with a clear framework for managing information security risks while supporting the organisation's strategic objectives. By formally defining responsibilities, reporting structures, and decision-making authority, the charter improves accountability and ensures that security activities are aligned with business priorities.

The charter also supports GHC's goals of maintaining customer trust, achieving regulatory excellence, driving innovation, and sustaining growth. From an investment perspective, it helps management prioritise security spending based on risk and business impact rather than reacting to incidents after they occur. This will enable the organisation to make informed decisions, improve operational resilience, and reduce the likelihood of costly security breaches or compliance failures.

This governance structure ensures that security is treated as a business enabler rather than simply a technical function, allowing GHC to grow securely and confidently in an increasingly complex threat environment.

Task 3: Board Reporting and Security Metrics

Board Executive Summary

Overall Security Posture: RED

After reviewing the security data from the last six months, GHC's overall security posture is currently rated Red. Although there has been a noticeable improvement in staff security awareness training, several key security indicators continue to move in the wrong direction. Phishing attempts, malware incidents, and high-risk security incidents have all increased steadily over the reporting period. At the same time, the organisation's patching rate has declined, leaving more systems vulnerable to potential attacks.

While it is encouraging to see more employees completing security awareness training, the increasing number of incidents suggests that training alone is not enough to address the current threat landscape. If these trends continue, GHC could face greater risks to patient data, regulatory compliance, business operations, and customer confidence. Management should therefore prioritise stronger security controls and a more proactive approach to risk management.

Selected Security Metrics

1. Phishing Attempts

Current Status: 320 attempts in February

Six-Month Trend: Increased from 150 to 320

Board Commentary

The number of phishing attempts targeting GHC has more than doubled during the reporting period. This shows that cybercriminals are increasingly targeting the organisation. If employees fall victim to these attacks, sensitive information could be exposed, and attackers may gain access to company systems.

2. Malware Incidents

Current Status: 50 incidents in February

Six-Month Trend: Increased from 25 to 50

Board Commentary

Malware incidents have shown a consistent upward trend, which may indicate weaknesses in current security controls. Continued growth in malware infections could lead to downtime, reduced productivity, and additional recovery costs for the organisation.

3. Critical Vulnerability Patching Rate

Current Status: 55%

Six-Month Trend: Declined from 67% to 55%

Board Commentary

The patching rate has gradually decreased over the last six months. This means some known security weaknesses are taking longer to fix, which could make it easier for attackers to exploit them.

4. Security Awareness Training Completion

Current Status: 70%

Six-Month Trend: Increased from 45% to 70%

Board Commentary

This is one of the few positive trends in the report. More employees are participating in security awareness training, which shows growing engagement with security practices. However, the increase in incidents suggests that additional awareness activities and technical safeguards are still required.

5. High-Risk Security Incidents

Current Status: 7 incidents in February

Six-Month Trend: Increased from 2 to 7

Board Commentary

The steady rise in high-risk incidents indicates that GHC's overall risk exposure is increasing. These incidents have the potential to affect business operations, damage the organisation's reputation, and negatively impact customer trust if not addressed quickly

Priority Risks and Issues

Risk 1: Rising Threat Activity

The growing number of phishing and malware incidents suggests that GHC is facing a higher level of external threat activity. If current controls are not strengthened, the likelihood of a serious security breach may continue to increase

Risk 2: Weak Vulnerability Management

The declining patching rate means that critical vulnerabilities are not being addressed fast enough. This creates unnecessary exposure to cyberattacks and could result in compliance issues or operational disruptions

Recommendations

Recommendation 1

Strengthen email security controls and implement multi-factor authentication across all systems. Combined with regular phishing simulations, this will help reduce the likelihood of successful phishing attacks

Recommendation 2

Introduce a formal vulnerability management programme with clear patching targets and regular progress reviews. This will help ensure critical security updates are applied within acceptable timeframes.

Rationale for Metric Selection

These five metrics were selected because they provide a balanced view of GHC's security performance. They highlight both areas of improvement and areas of concern, allowing the Board to understand the organisation's overall level of risk without focusing on technical details. Together, they provide insight into threat activity, control effectiveness, employee awareness, and the organisation's ability to manage security risks

Task 4: Security Steering Committee (SSC)

Security Steering Committee Terms of Reference

Purpose

The purpose of the Security Steering Committee (SSC) is to provide guidance and oversight for information security across GlobalHealth Connect (GHC). The committee ensures that security decisions support business objectives, reduce organisational risk, and promote collaboration between different departments. The SSC also serves as a platform for resolving security-related disagreements and ensuring that decisions are made in the best interests of the organisation

Scope

The committee will oversee key information security matters, including:

- Information security policies and standards.
- Security risks and mitigation strategies.
- Regulatory and compliance requirements.
- Security awareness initiatives.
- Major security incidents.
- Security projects and investments.
- Cross-functional security concerns and disputes

Membership

The SSC will consist of the following members:

- CEO (Chairperson)
- Director of Information Security Governance
- CTO
- IT Manager
- Compliance Officer
- HR Manager
- Finance Representative

Additional employees or subject matter experts may be invited when specialised input is required.

Responsibilities

The committee will:

- Review and discuss significant security risks.
- Approve or recommend security policies.
- Monitor progress on security initiatives.
- Review security performance reports and metrics.
- Resolve conflicts between security requirements and business needs.
- Promote security awareness throughout the organisation.
- Ensure security activities support GHC's strategic goals

Meeting Frequency

- The SSC will meet once a month. Additional meetings may be scheduled if urgent security issues or major incidents occur.

Decision-Making Authority

The committee has the authority to review, recommend, and approve security-related decisions within its scope. Where agreement cannot be reached, the matter will be escalated to the CEO for final consideration

Reporting

Updates from SSC meetings will be provided to executive management, and significant risks or decisions will be reported to the Board as required

First Security Steering Committee Meeting Agenda

Date: To Be Confirmed

1. Opening and Welcome

- Introduction of members.
- Purpose and objectives of the SSC.

2. Review of Current Security Environment

- Overview of recent security risks and incidents.
- Discussion of key security metrics.

3. Password Policy Discussion (Key Agenda Item)

Issue: The IT Manager supports implementing 16-character complex passwords that must be changed every 30 days. The CTO believes this approach may frustrate users and negatively affect productivity. Instead, the CTO recommends using multi-factor authentication and password management tools

Discussion Points:

- Security benefits of stronger passwords.
- User experience and operational impact.
- Industry best practices.
- MFA implementation.
- Password manager adoption.

4. Compliance and Risk Updates

- Regulatory compliance status.
- Review of current security risks.

5. Future Security Priorities

- Identify upcoming security projects.
- Discuss resource requirements.

6. Action Items and Meeting Closure

Briefing Note to the CEO

Subject: Role of the Security Steering Committee in Resolving Security Conflicts

The Security Steering Committee has been established to ensure that security decisions are made collaboratively and align with the organisation's business goals. By bringing together representatives from different departments, the committee provides a structured way to discuss security challenges and reach balanced decisions that consider both security requirements and operational needs.

Regarding the current password policy disagreement, the SSC will allow both the IT Manager and CTO to present their perspectives before a decision is made. Rather than focusing only on security or convenience, the committee will evaluate the risks, business impact, user experience, and industry best practices. This approach will help GHC implement security controls that are effective, practical, and aligned with the organisation's overall objectives.

Task 5: Governance Maturity Assessment

5.1 Current Maturity Assessment

Governance Domain	Current Level	Justification
Policy & Documentation	Level 2 (Initial)	GHC has some security policies in place, but they are inconsistent because they were inherited from different acquisitions and are not regularly updated.
Roles & Responsibilities	Level 1 (Ad Hoc)	Security responsibilities are not clearly defined, which makes accountability difficult across the organisation.
Risk Management	Level 1 (Ad Hoc)	The organisation mainly reacts to security issues after they happen instead of identifying and managing risks proactively.
Metrics & Reporting	Level 2 (Initial)	Security metrics are collected, but they are not always presented in a way that helps management understand business impact.
Training & Awareness	Level 2 (Initial)	Security awareness training exists, but employee engagement remains low and participation could be improved.
Compliance	Level 2 (Initial)	Compliance activities are largely driven by

		audits instead of being monitored on an ongoing basis.
--	--	--

5.2 12-18 Month Maturity Roadmap

Initiative 1: Establish a Formal Security Governance Structure

Objective

Create clear ownership and accountability for information security across the organisation.

Key Activities

- Appoint a Director of Information Security Governance.
- Establish the Security Steering Committee.
- Define roles and responsibilities for key stakeholders.

Expected Outcome

Security responsibilities will be clearly defined, and decision-making processes will become more consistent across the organisation.

Initiative 2: Standardise Policies and Documentation

Objective

Ensure that all security policies are current, consistent, and aligned with business goals.

Key Activities

- Review existing policies inherited from acquisitions.
- Update outdated policies.
- Create a regular review and approval process.

Expected Outcome

All departments will work from the same set of security policies, reducing confusion and improving compliance.

Initiative 3: Implement a Formal Risk Management Process

Objective

Move from a reactive approach to a proactive approach to managing risks.

Key Activities

- Develop a risk register.
- Conduct quarterly risk assessments.
- Assign risk owners for major risks.

Expected Outcome

Management will have better visibility of security risks and be able to make more informed decisions before problems occur.

Initiative 4: Improve Security Reporting and Metrics**Objective**

Provide management and the Board with clearer insights into security performance.

Key Activities

- Define security KPIs and reporting requirements.
- Create regular management reports.
- Link security metrics to business risks and objectives.

Expected Outcome

Decision-makers will have access to meaningful information that supports better governance and risk management.

Initiative 5: Strengthen Security Awareness and Compliance Monitoring**Objective**

Improve employee engagement and create a stronger security culture.

Key Activities

- Run quarterly awareness campaigns.
- Conduct phishing simulation exercises.
- Monitor compliance throughout the year instead of only during audits.

Expected Outcome

Employee participation in security initiatives will improve, and compliance issues will be identified and addressed earlier.

5.3 Executive Summary to the Board

The maturity assessment shows that GlobalHealth Connect is currently operating between Level 1 (Ad Hoc) and Level 2 (Initial) across most governance areas. Although some security processes exist, many are not consistently applied, and responsibilities are not always clearly defined. This makes it difficult for the organisation to manage security risks effectively and maintain a consistent approach to governance.

The proposed roadmap focuses on building a stronger governance foundation by improving accountability, standardising policies, introducing formal risk management processes, and strengthening security awareness. These initiatives will help GHC move towards Level 3 (Defined), where security processes are documented, understood, and applied consistently across the organisation.

Achieving this level of maturity is important because it will help the organisation support future growth, improve compliance, protect sensitive patient information, and maintain the trust of customers and stakeholders. By investing in these improvements now, GHC will be better prepared to manage emerging security risks and meet its long-term business objectives